3. Detailed API Design — PT. XYZ Online Lending Mobile App

3.1 API Base URL & Convention

- **Base URL**: `https://api.xyz-lending.co.id/v1`
- **Format**: RESTful JSON API
- **Authentication**: Bearer Token (JWT)
- **Content-Type**: `application/json` (kecuali file upload: `multipart/form-data`)

Standard Response Format

```
{
  "success": true,
  "message": "Operation successful",
  "data": { ... },
  "meta": {
    "page": 1,
    "per_page": 10,
    "total": 100
  }
}
```

Standard Error Response

```
{
  "success": false,
  "message": "Validation failed",
  "errors": [
    { "field": "email", "message": "Email sudah terdaftar" }
  ]
}
```

3.2 API Endpoints

3.2.1 Auth Service

POST /auth/register

Registrasi user baru (Step 1 — data personal).

Request Body:

```
{
  "full_name": "John Doe",
  "email": "john@example.com",
  "phone": "081234567890",
  "password": "SecureP@ss123",
```

```
  "password_confirmation": "SecureP@ss123"
}
```

Response (201 Created):

```
{
  "success": true,
  "message": "Registrasi berhasil. Silakan upload dokumen.",
  "data": {
    "user_id": "550e8400-e29b-41d4-a716-446655440000",
    "otp_sent": true
  }
}
```

POST /auth/verify-otp

Verifikasi OTP yang dikirim ke nomor telepon.

Request Body:

```
{
  "phone": "081234567890",
  "otp_code": "123456"
}
```

Response (200 OK):

```
{
  "success": true,
  "message": "OTP terverifikasi",
  "data": {
    "access_token": "eyJhbGciOi...",
    "refresh_token": "dGhpcyBpcyBh...",
    "expires_in": 3600
  }
}
```

POST /auth/login

Login dengan email dan password.

Request Body:

```
{
  "email": "john@example.com",
  "password": "SecureP@ss123"
}
```

Response (200 OK):

```
{
  "success": true,
  "data": {
```

```
    "access_token": "eyJhbGciOi...",
    "refresh_token": "dGhpcyBpcyBh...",
    "expires_in": 3600,
    "user": {
      "id": "550e8400-e29b-41d4-a716-446655440000",
      "full_name": "John Doe",
      "email": "john@example.com",
      "is_verified": true,
      "biometric_enabled": true
    }
  }
}
```

POST /auth/login/biometric

Login menggunakan biometric token.

Request Body:

```
{
  "user_id": "550e8400-e29b-41d4-a716-446655440000",
  "biometric_token": "device_signed_token_here"
}
```

Response: Sama dengan POST /auth/login.

POST /auth/refresh-token

Refresh expired access token.

Request Body:

```
{
  "refresh_token": "dGhpcyBpcyBh..."
}
```

POST /auth/forgot-password

Request reset password link via email.

Request Body:

```
{
  "email": "john@example.com"
}
```

POST /auth/logout

Invalidate current session.

Headers: `Authorization: Bearer <access_token>`

3.2.2 User Service

GET /users/me

Get current user profile.

Headers: `Authorization: Bearer <access_token>`

Response (200 OK):

```
{
  "success": true,
  "data": {
    "id": "550e8400-e29b-41d4-a716-446655440000",
    "full_name": "John Doe",
    "email": "john@example.com",
    "phone": "081234567890",
    "is_verified": true,
    "biometric_enabled": true,
    "documents": [
      { "type": "selfie", "verified": true },
      { "type": "ktp", "verified": true }
    ],
    "created_at": "2026-01-15T10:30:00Z"
  }
}
```

PUT /users/me

Update user profile.

PUT /users/me/biometric

Enable/disable biometric authentication.

Request Body:

```
{
  "enabled": true,
  "biometric_token": "device_signed_token_here"
}
```

3.2.3 Document Service

POST /documents/upload

Upload foto selfie atau KTP (Step 2 registrasi).

Headers: `Authorization: Bearer <access_token>`
Content-Type: `multipart/form-data`

Form Data: - `doc_type`: `selfie` | `ktp` - `file`: Binary file (JPEG/PNG, max 5MB)

Response (201 Created):

```
{
  "success": true,
  "message": "Dokumen berhasil diupload",
  "data": {
    "document_id": "660e8400-e29b-41d4-a716-446655440001",
    "doc_type": "ktp",
    "file_url": "https://storage.xyz-lending.co.id/docs/ktp_550e84.jpg",
    "verification_status": "processing"
  }
}
```

GET /documents

Get all documents milik user.

3.2.4 Loan Service

GET /loans/eligibility

Cek apakah user eligible untuk mengajukan pinjaman.

Headers: `Authorization: Bearer <access_token>`

Response (200 OK):

```
{
  "success": true,
  "data": {
    "eligible": true,
    "max_amount": 12000000,
    "max_tenor_months": 12,
    "interest_rate": 1.5,
    "reason": null
  }
}
```

Response jika tidak eligible:

```
{
  "success": true,
  "data": {
    "eligible": false,
    "reason": "Anda masih memiliki pinjaman aktif yang belum dilunasi"
  }
}
```

POST /loans/simulate

Simulasi cicilan pinjaman.

Request Body:

```
{
  "amount": 10000000,
  "tenor_months": 12
}
```

Response (200 OK):

```
{
  "success": true,
  "data": {
    "amount": 10000000,
    "tenor_months": 12,
    "interest_rate": 1.5,
    "monthly_payment": 916667,
    "total_interest": 1000000,
    "total_payment": 11000000,
    "installments": [
      { "month": 1, "principal": 833333, "interest": 83333, "total": 916667,
"remaining": 9166667 },
      { "month": 2, "principal": 833333, "interest": 83333, "total": 916667,
"remaining": 8333333 }
    ]
  }
}
```

POST /loans

Ajukan pinjaman baru.

Headers: `Authorization: Bearer <access_token>`

Request Body:

```
{
  "amount": 10000000,
  "tenor_months": 12,
  "purpose": "Modal usaha"
}
```

Response (201 Created):

```
{
  "success": true,
  "message": "Pengajuan pinjaman berhasil. Menunggu proses approval.",
  "data": {
    "loan_id": "770e8400-e29b-41d4-a716-446655440002",
```

```
    "amount": 10000000,
    "tenor_months": 12,
    "status": "pending",
    "created_at": "2026-02-15T14:00:00Z"
  }
}
```

GET /loans

Get semua pinjaman milik user.

Query Params: `?status=active&page=1&per_page=10`

GET /loans/{loan_id}

Get detail pinjaman tertentu.

Response (200 OK):

```
{
  "success": true,
  "data": {
    "id": "770e8400-e29b-41d4-a716-446655440002",
    "amount": 10000000,
    "tenor_months": 12,
    "interest_rate": 1.5,
    "monthly_payment": 916667,
    "total_payment": 11000000,
    "outstanding_balance": 5500000,
    "status": "active",
    "approved_at": "2026-02-16T09:00:00Z",
    "disbursed_at": "2026-02-16T10:00:00Z",
    "next_payment": {
      "installment_no": 7,
      "amount_due": 916667,
      "due_date": "2026-08-16"
    }
  }
}
```

3.2.5 Payment Service

GET /loans/{loan_id}/payments

Get daftar cicilan/tagihan untuk satu pinjaman.

Response (200 OK):

```
{
  "success": true,
```

```
  "data": [
    {
      "id": "880e8400-e29b-41d4-a716-446655440003",
      "installment_no": 1,
      "amount_due": 916667,
      "amount_paid": 916667,
      "due_date": "2026-03-16",
      "paid_date": "2026-03-14",
      "status": "paid"
    },
    {
      "id": "880e8400-e29b-41d4-a716-446655440004",
      "installment_no": 2,
      "amount_due": 916667,
      "amount_paid": 0,
      "due_date": "2026-04-16",
      "paid_date": null,
      "status": "pending"
    }
  ]
}
```

GET /payments/summary

Get ringkasan hutang dan tagihan user (untuk dashboard).

Response (200 OK):

```
{
  "success": true,
  "data": {
    "has_active_loan": true,
    "outstanding_balance": 5500000,
    "current_month_bill": {
      "payment_id": "880e8400-e29b-41d4-a716-446655440004",
      "amount_due": 916667,
      "due_date": "2026-04-16",
      "status": "pending"
    },
    "total_paid": 5500000,
    "total_remaining": 5500000
  }
}
```

3.2.6 Notification Service

GET /notifications

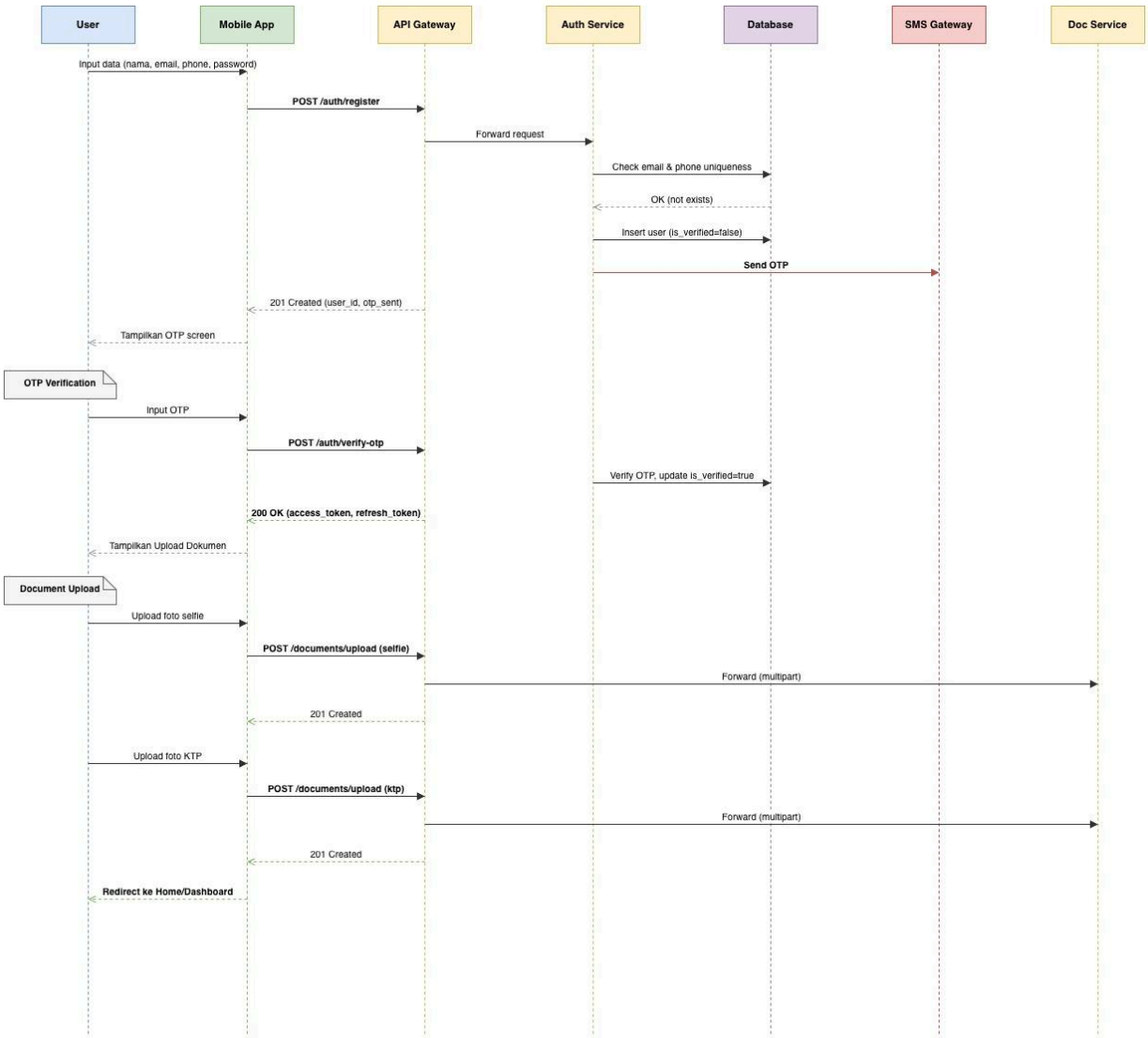
Get daftar notifikasi user.

Query Params: `?page=1&per_page=20`

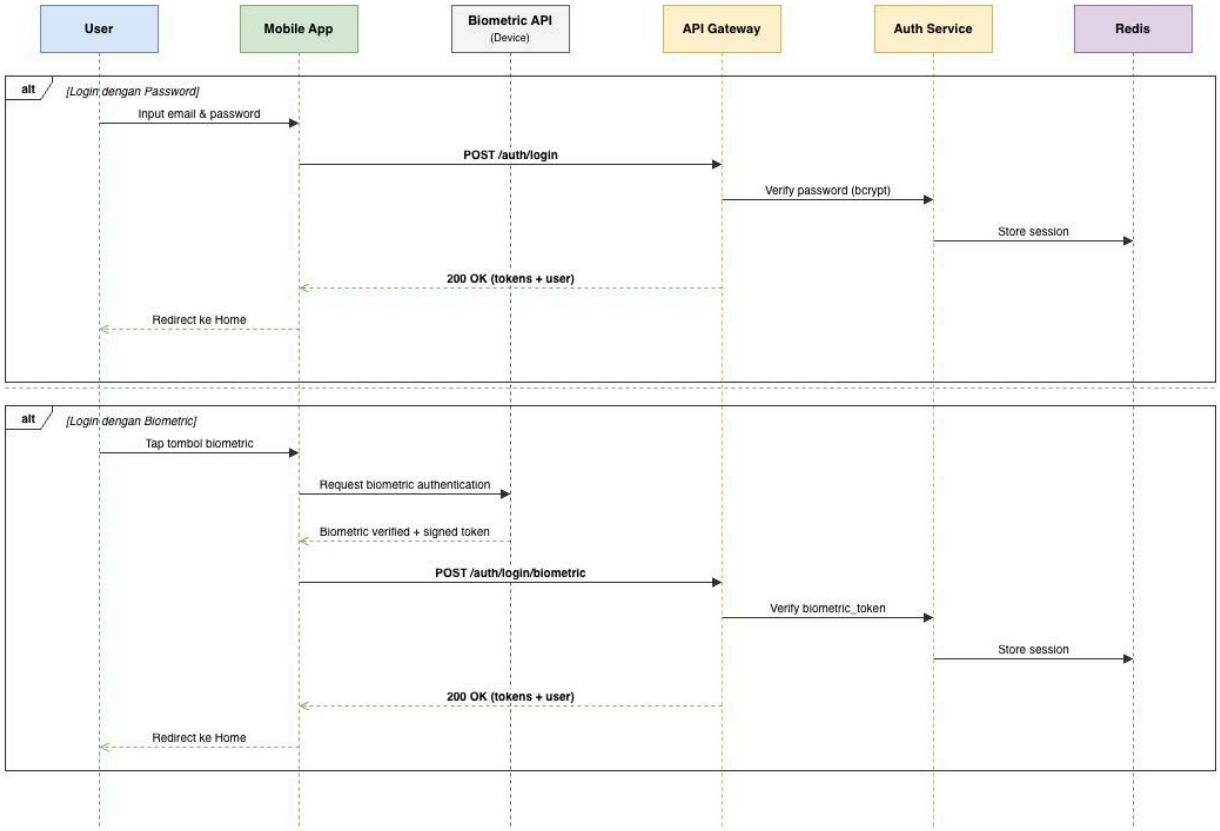
PUT /notifications/{id}/read

Mark notifikasi sebagai sudah dibaca.

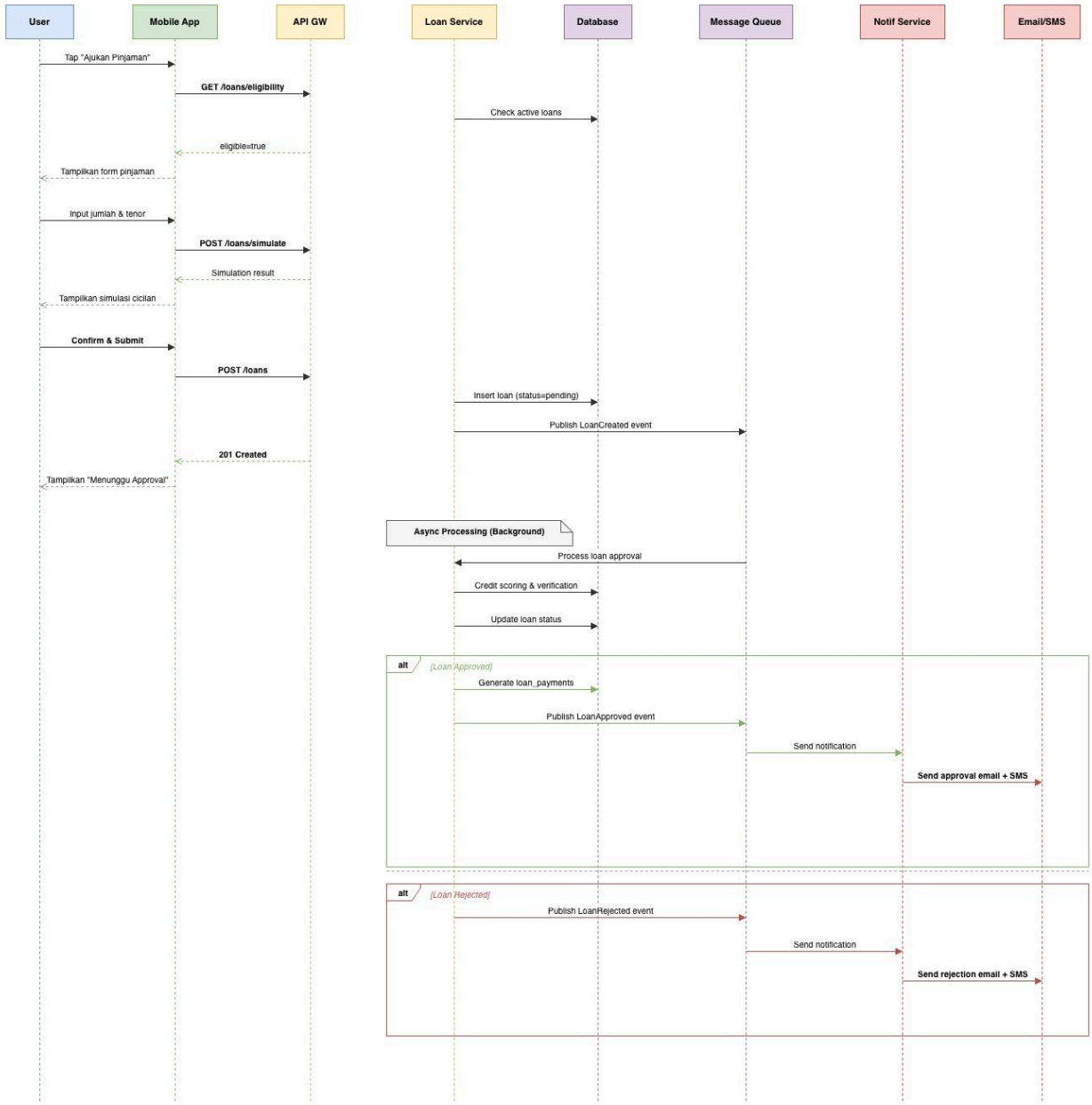
3.3 Sequence Diagram — Registrasi User



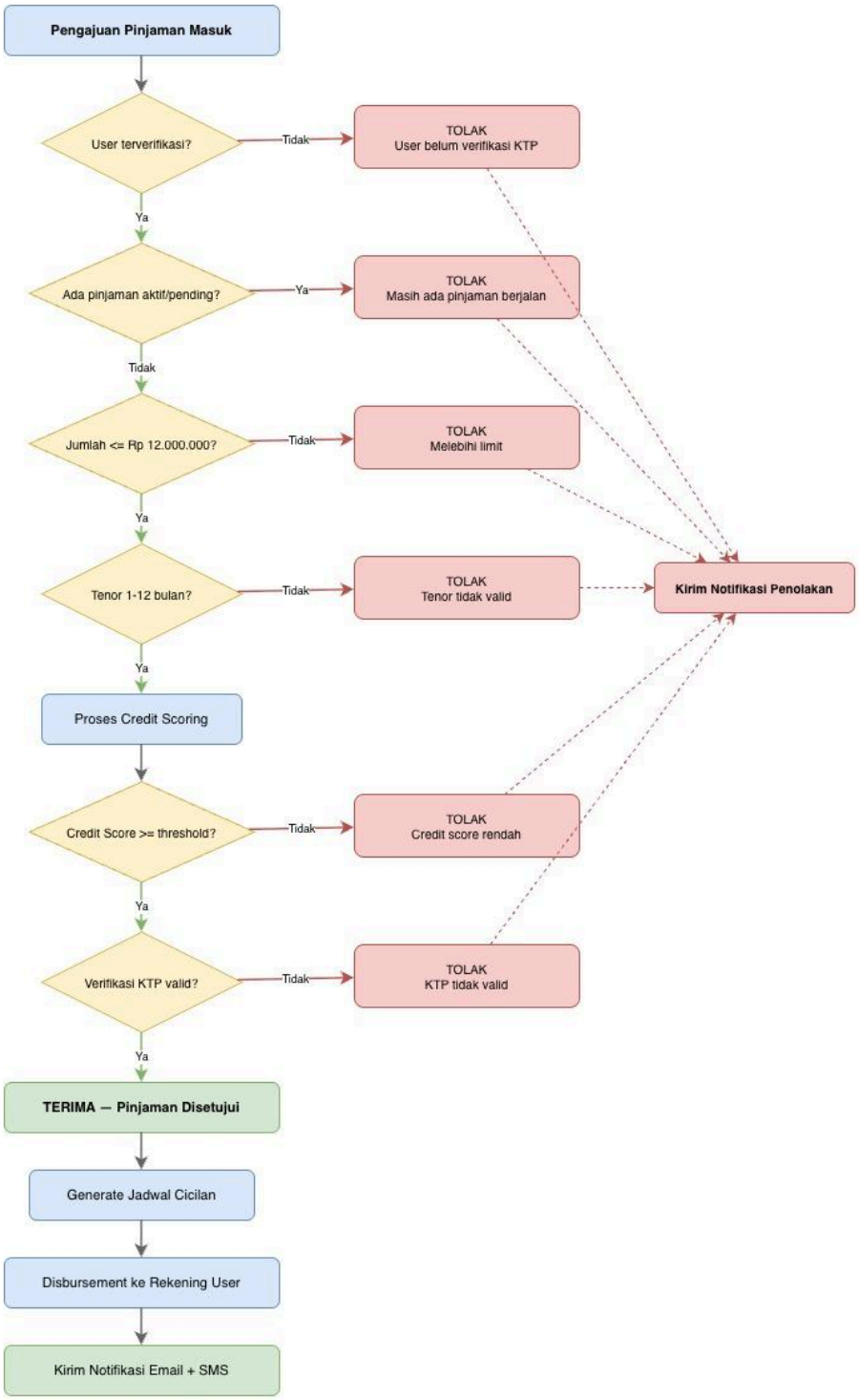
3.4 Sequence Diagram — Login (Password & Biometric)



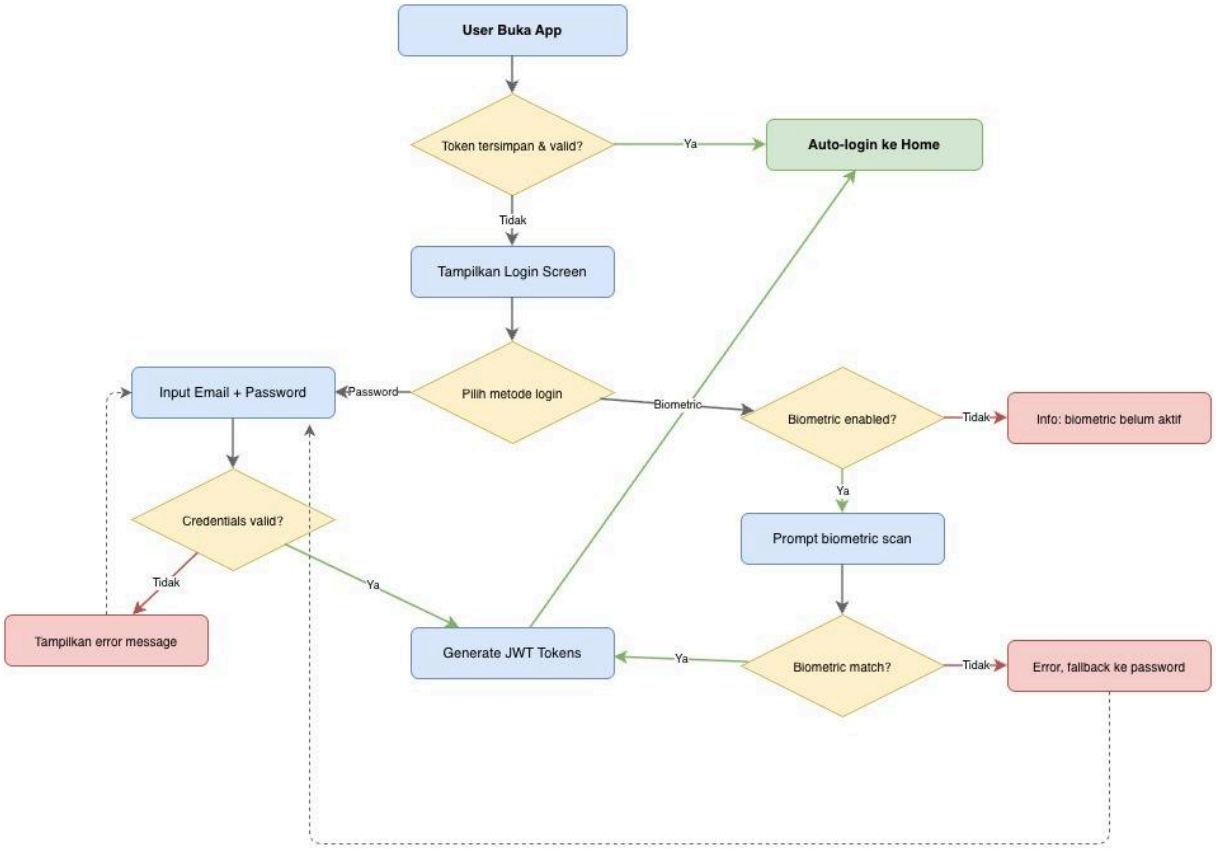
3.5 Sequence Diagram — Pengajuan Pinjaman



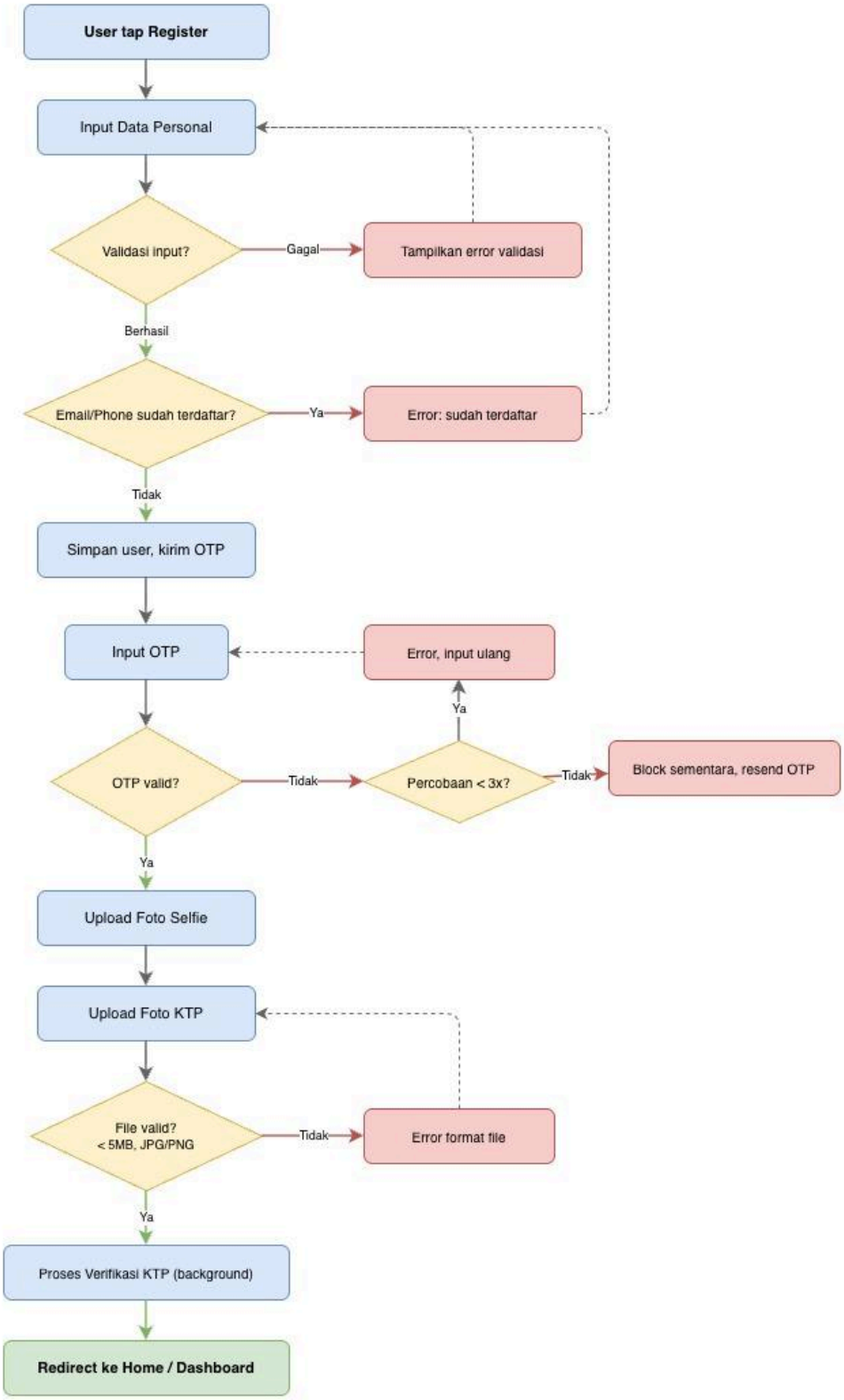
3.6 Flowchart — Proses Approval Pinjaman



3.7 Flowchart — Proses Login



3.8 Flowchart — Registrasi User



3.9 API Summary Table

Method	Endpoint	Auth	Description
POST	/auth/register	No	Registrasi user baru
POST	/auth/verify-otp	No	Verifikasi OTP
POST	/auth/login	No	Login dengan password
POST	/auth/login/biometric	No	Login dengan biometric
POST	/auth/refresh-token	No	Refresh JWT token
POST	/auth/forgot-password	No	Request reset password
POST	/auth/logout	Yes	Logout / invalidate session
GET	/users/me	Yes	Get user profile
PUT	/users/me	Yes	Update user profile
PUT	/users/me/biometric	Yes	Enable/disable biometric
POST	/documents/upload	Yes	Upload foto/KTP
GET	/documents	Yes	List dokumen user
GET	/loans/eligibility	Yes	Cek eligibility pinjaman
POST	/loans/simulate	Yes	Simulasi cicilan
POST	/loans	Yes	Ajukan pinjaman
GET	/loans	Yes	List pinjaman user
GET	/loans/{id}	Yes	Detail pinjaman
GET	/loans/{id}/payments	Yes	List cicilan pinjaman
GET	/payments/summary	Yes	Summary tagihan (dashboard)
GET	/notifications	Yes	List notifikasi

Method	Endpoint	Auth	Description
PUT	/notifications/{id}/read	Yes	Mark notifikasi dibaca

3.10 HTTP Status Codes

Code	Usage
200	Successful GET/PUT request
201	Successful POST (resource created)
400	Bad Request (validation error)
401	Unauthorized (invalid/missing token)
403	Forbidden (insufficient permissions)
404	Resource not found
409	Conflict (e.g. duplicate email)
422	Unprocessable Entity (business rule violation)
429	Too Many Requests (rate limit)
500	Internal Server Error